SECURE-RAG: Auditing Retrieval and Lightweight Adaptation for Cybersecurity Claim Verification

Tulsi Sanskrati Tomar

S24CSEU0084
School of Computer Science Engineering and Technology
Bennett University, Greater Noida, India

***Abstract*—Large language models can produce plausible explanations of cybersecurity evidence without necessarily reaching the right conclusion. This paper investigates that gap using Qwen2.5 3B and three separate experiments: a 2,367-example evaluation across six SECURE tasks, a study of 160 structured claims drawn from 40 additional CVEs, and a matched low-rank adaptation trial using MLX. Evidence-first prompting increases Knowledge of Common Vulnerabilities (KCV) accuracy from 46.10% to 63.12%, but does not improve every task. In the additional CVE study, a retrieval-based approach that provides citations reaches 68.125% accuracy, compared with 91.25% when the model receives the complete source record. Of 142 answers with matching literal citations, 47 still have incorrect verdicts. A fixed 100-step LoRA adapter trained on 262 development examples improves matched KCV validation accuracy from 34/53 (64.15%) to 42/53 (79.25%), with a paired source-cluster interval of [+3.57, +27.27] percentage points. It also returns the expected X label for 52/53 VOOD examples, although all validation examples in that task have the same label. Together, these findings show that citations are not a guarantee of correct evidence interpretation and that lightweight adaptation can improve a measured validation result. Transfer to previously unobserved CVEs has not yet been established.**

***Index Terms*—cybersecurity, SECURE, claim verification, retrieval-augmented generation, LoRA, local language models**

I. Introduction

A cybersecurity assistant should do more than recognize a vulnerability identifier. It must also decide whether the available evidence supports a claim, contradicts it, or leaves the answer uncertain. Details such as affected software versions and user-interaction requirements can change the meaning of an otherwise convincing response. We study these decisions with a small locally deployed language model and the SECURE benchmark [1].

Our starting point was a practical question: would more explicit reasoning and additional retrieved evidence help the model make better decisions? We first compared prompting strategies across the six benchmark tasks. We then tested whether a retrieval system that supplied direct citations would improve decisions on a separate set of CVE claims. Finally, we trained a small LoRA adapter and compared it with the same quantized base model under matched inference settings.

These experiments answer related questions, but they are not interchangeable. The six-task test measures prompting behavior, the additional CVE collection examines a fixed retrieval candidate, and the adapter study measures a supervised change on a separate validation partition. A high score on a development pilot cannot be presented as test accuracy, just as a difference between two inference runtimes cannot be attributed to training alone.

The contribution of this paper is therefore empirical rather than algorithmic. We provide a reproducible local evaluation, report where evidence-oriented prompting succeeds and fails, document a case in which literal citations accompany incorrect decisions, and measure a fixed adapter against its matched base. Retrieval and LoRA are established methods; we do not present them as new algorithms or claim superiority over the original SECURE study. The work addresses three questions: (RQ1) Does evidence-oriented prompting improve all task families? (RQ2) Does a matching citation imply a correct verdict? (RQ3) Does a small supervised adapter improve KCV decisions under a controlled comparison?

II. Background and Related Work

A. The SECURE benchmark

Bhusal *et al.* introduced SECURE to evaluate language models on cybersecurity advisory tasks [1]. Its six tasks are Malware and Attack Extraction (MAET), Common Weakness Enumeration Extraction (CWET), Knowledge of Common Vulnerabilities (KCV), Vulnerabilities Out of Distribution (VOOD), Risk Evaluation and Reasoning (RERT), and CVSS Problem Solving (CPST). The original study investigated multiple models and customized approaches, including retrieve-read methods, and identified irrelevant retrieval and missing decisive evidence as potential sources of error.

We use official benchmark data at revision `a2412e8`. Historical SECURE results are useful context but are not controlled baselines for our local model: model size, prompts, subsets, quantization and scoring may differ. The original study also evaluated customization, so using RAG or fine-tuning is not by itself a novel research contribution.

B. Retrieval and evidence interpretation

Retrieval-augmented generation supplies external information that a model can consult when answering a question [2]. Its benefit depends both on retrieving the right passage and on reading that passage correctly. An answer may quote a source word for word while drawing the opposite conclusion from what the quoted statement means. For this reason, our retrieval experiment treats literal citation matching and verdict accuracy as different measurements. Neither replaces an independently reviewed judgment of entailment.

C. Lightweight adaptation

LoRA modifies a pretrained model by learning low-rank updates while leaving its original weight matrices frozen [3]. The effective matrix is commonly written as $W' = W + sBA$, where the rank of BA is much smaller than the dimensions of W. Our adapter uses rank eight in the final four transformer layers. The goal is to test whether a modest, feasible local update changes claim-verification behavior, not to introduce a new adaptation procedure. HMS-IDS [4] illustrates how a cybersecurity system can be described and evaluated in stages; its intrusion-detection setting differs from our claim-verification task and its accuracy is not a direct comparator.

III. Data and Evaluation Design

A. Official benchmark and source separation

The preparation process verifies exact SHA-256 hashes for all six upstream TSV files. Connected source URLs, shared CVE mentions where relevant, identical prompts and repeated CVSS vectors are grouped before the development, validation and test partitions are assigned. Historical pilot sources remain in development. These precautions reduce direct source reuse and prevent repeated variants from being treated as independent observations.

The archived six-task test contains 2,367 examples: 602 MAET, 572 CWET, 282 KCV, 282 VOOD, 569 RERT and 60 CPST. We compare the original benchmark prompts, evidence-first structured prompts and a subsequent self-review call. These test outcomes have already been observed; the partition cannot be reused as an untouched test for later method selection. An earlier 144-example pilot produced 93.75% pooled accuracy, but that result is historical development evidence and is not the main paper result.

B. Additional structured CVE claims

The Fresh V3 collection contains 160 claims from 40 distinct 2025 CVEs, with four claims per CVE. They concern two explicit fields in recorded CNA CVSS v3.1 data: base severity and user interaction. The collection contains 80 true and 80 false claims, divided evenly between the two claim families. Labels were produced from documented JSON pointers and checked against archived records. Independent human review of those labels is still pending.

TABLE I
Separate experimental collections; observed validation is not a new test.

Collection	Rows	Groups	Purpose
Six-task test	2,367	By task	Prompt study
Fresh V3	160	40 CVEs	Retrieval study
LoRA development	262	34	Training pool
LoRA validation	106	14	Matched comparison

An audit found no CVE-ID intersection with 3,108 identifiers in the six official TSV files. This establishes separation from those dataset identifiers, not that the pretrained model had never encountered the same vulnerabilities. We inspected the V3 results before making subsequent research decisions, so V3 is now observed development evidence rather than a new untouched evaluation set.

C. Adapter development and validation

The LoRA training pool contains 262 KCV and VOOD development examples from 34 connected source groups, with 131 examples from each task. Validation uses 53 KCV and 53 VOOD examples from 14 different groups. The archived audit reports no source-group, CVE-ID or exact-prompt overlap between these partitions. Validation prompts do not include gold labels or assistant completions.

The KCV validation labels consist of 20 T and 33 F cases. A model that always predicts F would therefore achieve 62.26%. All 53 VOOD validation labels are X, making an always-X predictor a 100% control. This matters when interpreting apparent gains in abstention behavior.

IV. Methodology and Implementation

A. Prompt comparison without retrieval

The six-task experiment runs Qwen2.5 3B Instruct through Ollama with Q4_K_M quantization. The original condition uses the benchmark prompt. In the evidence-first condition, the model provides a concise analysis and answer in a fixed JSON schema. The self-review condition supplies the original question and the preceding answer, then asks the same model to retain or revise that answer. Self-review is another inference step, not an independent verifier. None of these reported model-only verdicts uses external retrieval or a deterministic answer rule.

The recorded settings include temperature 0.7, a requested 32,768-token context and a 512-token output allowance. The predefined parser scores responses as written, without repairing them after consulting gold labels. The self-review condition also incurs the cost of the preceding evidence-first call.

B. Fixed retrieval comparison

For Fresh V3, we compare three conditions: the original prompt with the full source record; a top-three retrieval

condition with JSON verdict control; and a condition using the same top-three passages while also requesting a citation, reasoning, confidence and a verdict. All arms use the same installed model digest and inference settings, including a fixed generation seed. There is no additional verifier. The user-interaction field follows the FIRST CVSS v3.1 specification [5].

The full-record and retrieved conditions differ in what information is selected, how it is represented and what instructions are given. Their difference therefore measures the performance of complete systems, not a single isolated retrieval effect. The two top-three conditions better control the passages, although citation, reasoning and confidence are still introduced together.

C. Matched MLX adapter trial

The adaptation experiment uses `mlx-community/Qwen2.5-3B-Instruct-4bit` at revision `4f83f8f`. Both validation conditions use this exact checkpoint and tokenizer, the same prompt format, greedy decoding and a 16-token output limit. Only adapter loading changes. This matched comparison is necessary because comparing an MLX adapter with the Ollama baseline would mix training effects with runtime and quantization differences.

Training uses MLX and MLX-LM 0.32.2 on an Apple M3 Pro with 18 GiB unified memory. The fixed setup has rank eight, scale 16, zero dropout, batch size one, learning rate 10^{-5}, gradient checkpointing and a 4,096-token maximum training sequence. Prompt tokens are masked from the loss, and training completions contain only T, F or X, without added reasoning traces, retrieved text or generated labels.

The predetermined run uses seed 20261101 and 100 batch-one updates sampled from the 262-example pool. It is not a full epoch. We retain the step-100 checkpoint, containing 1,662,976 trainable parameters (approximately 0.054% of the reported 3.086-billion-parameter model). A strict parser accepts only normally completed, single-letter responses. All validation responses from both arms are valid.

D. Metrics and uncertainty

Classification accuracy is the proportion of exact-label matches, counting invalid responses as errors. Binary coverage is the share of responses labeled T or F. For RERT, we use the recorded ROUGE-L F1 calculation with lowercase ASCII alphanumeric tokens, no stemming and longest-common-subsequence overlap; it reflects reference overlap rather than factual correctness. CPST uses penalized mean absolute deviation, assigning an invalid response the maximum error of ten. Lower CPST values are better.

In paired comparisons, each example contributes $d_i = \mathbb{1}(\hat{y}_i^{\text{new}} = y_i) - \mathbb{1}(\hat{y}_i^{\text{base}} = y_i)$, and the average $\Delta = N^{-1}\sum_i d_i$ is the observed accuracy change. Bootstrap intervals resample connected source groups instead of treating correlated claims independently. The archive records 2,000 draws with seed 20261031. These intervals capture source variation within one recorded run; they do not include training-seed or model-family uncertainty and are not adjusted for multiple comparisons. We do not combine accuracy, ROUGE-L and CPST error into a single score.

V. Results and Analysis

A. Prompting produces uneven gains

Table II shows why the six tasks should not be reduced to a single performance headline. Evidence-first prompting raises KCV accuracy from 46.10% to 63.12%, and self-review maintains that result. VOOD also improves, reaching 79.79% with self-review. By contrast, MAET declines under both modified prompts. RERT reference overlap falls, while CPST error becomes much larger, especially for evidence-first prompting, which produces 52 invalid CPST answers out of 60. Those failures remain in the score because a response that cannot be parsed is a failure of the evaluated system.

B. Matching citations do not ensure correct verdicts

On Fresh V3, the full-record condition answers 146/160 claims correctly (91.25%). Accuracy drops to 78/160 (48.75%) with top-three retrieval and JSON verdict control. Adding the citation/reasoning/confidence bundle improves the retrieved condition to 109/160 (68.125%), but it remains 23.125 percentage points below the full-record condition. The paired 95% CVE-cluster interval for that difference is $[-28.125, -18.125]$ points. Compared with the full-record condition, the cited approach repairs four errors but changes 41 previously correct decisions into errors. One response uses up its output budget without producing a valid verdict.

The breakdown by claim family explains much of this loss. On severity claims, cited retrieval is slightly ahead of the full record (74/80 versus 73/80). On user-interaction claims, however, it reaches only 35/80 against 73/80 for the full-record condition. In particular, it predicts F for every one of the 40 true user-interaction claims. The overall accuracy would hide this systematic failure.

Literal quotations are common but not reliable evidence of a correct decision. Of 159 complete binary answers in the cited condition, 142 quote text that matches a named supplied passage. Forty-seven of those 142 verdicts are nevertheless wrong (33.10%). Among 140 complete answers that state confidence 100, 42 are wrong (30%). These values describe this specific experiment; they do not establish general calibration properties.

One saved answer for CVE-2025-41244 makes the failure especially clear. It quotes a source field indicating that user interaction is `NONE`, then rejects a claim saying interaction is not required. The correct field appears in the quotation, but the model reverses its meaning. This is an inspected archived response, not an independently completed human entailment annotation. An explicit source-field line appears

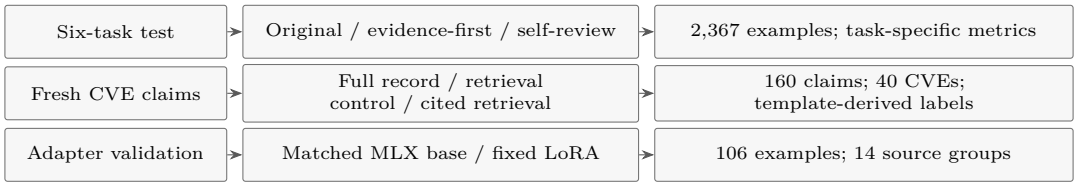


Fig. 1. Overview of the three experiments. Collections and inference conditions differ, so cross-runtime differences are not interpreted as isolated adaptation effects.

TABLE II
RECORDED SIX-TASK TEST RESULTS. CLASSIFICATION SCORES ARE PERCENTAGES; RERT AND CPST RETAIN THEIR RESPECTIVE SCALES.

Task	Metric	N	Original	Evidence-first	Self-review
MAET	Accuracy (%)	602	74.92	74.09	72.26
CWET	Accuracy (%)	572	72.20	72.90	72.73
KCV	Accuracy (%)	282	46.10	63.12	63.12
VOOD	Accuracy (%)	282	54.26	70.21	79.79
RERT	ROUGE-L F1	569	0.4323	0.1614	0.2549
CPST	Penalized MAD (lower better)	60	1.9400	8.8708	3.4908

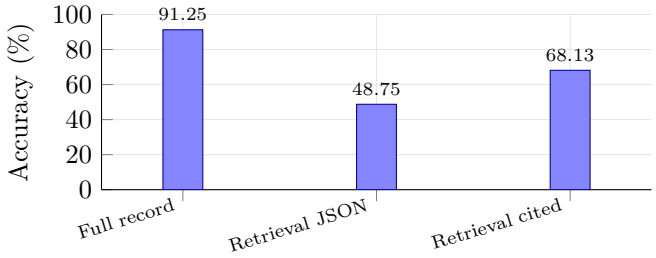


Fig. 2. Verdict accuracy for 160 template-derived CVE claims. Cited retrieval improves on its retrieval control but remains below the full-record condition.

in the top-three passages for 142/160 claims; even so, the presence or absence of that line alone cannot establish a causal explanation, because related information can appear elsewhere in the source.

C. The adapter improves matched KCV validation

Under identical MLX inference settings, the base model answers 34/53 KCV validation examples correctly (64.15%), while the step-100 adapter answers 42/53 (79.25%). This is a gain of 15.09 percentage points. Eleven base-model errors are corrected and three previously correct answers become wrong. The paired source-cluster interval is [+3.57, +27.27] points. It is a positive result on the observed validation examples from 14 groups, with one training seed.

The class-level changes show what improved. Recall for true claims rises from 4/20 to 13/20, while recall for false claims changes from 30/33 to 29/33. Macro-F1 across T and F rises from 0.5464 to 0.7814. In other words, the adapter reduces the base model's tendency to predict F and recovers more supported claims. Of the 11 remaining KCV errors, seven are true claims rejected as F, three are false claims accepted as T, and one false claim receives X. The three regressions are `kcv-0005`, `kcv-0316` and `kcv-0352`.

TABLE III
MATCHED MLX VALIDATION, WITH 53 EXAMPLES PER TASK.

Measurement	Base	Adapter	Constant control
KCV correct	34	42	33 (F)
KCV accuracy (%)	64.15	79.25	62.26
VOOD correct	0	52	53 (X)
VOOD accuracy (%)	0.00	98.11	100.00

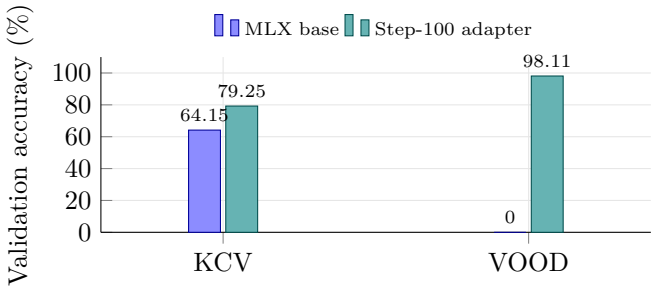


Fig. 3. Validation performance against the matched MLX base. Uniform X labels limit the interpretation of VOOD accuracy.

VOOD also changes sharply: the base gives 53 unsupported F answers, whereas the adapter gives 52 X answers and one unsupported T. This is 0/53 versus 52/53 correct. It demonstrates that the adapter learned to use X in these prompts, but it is not evidence of general, calibrated uncertainty handling. An always-X predictor would score 53/53 on this all-X validation set. We therefore report KCV and VOOD separately instead of pooling their accuracy into one headline.

D. Runtime and reproducibility

The recorded adapter training takes 501.23 seconds (8.35 minutes), including validation-loss passes but excluding installation and model download. Inference over the 106

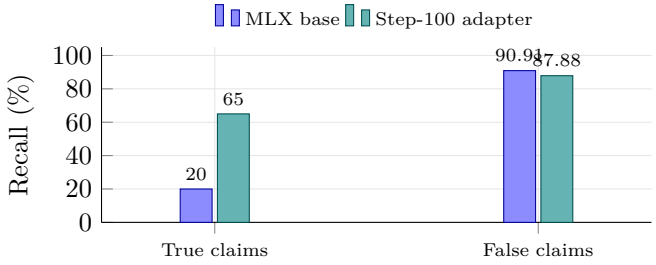


Fig. 4. KCV recall by label: 20 true and 33 false claims. The main improvement comes from recovering true claims, with a small decline on false claims.

validation examples takes 96.05 seconds for the base and 97.72 seconds for the adapter. Because of stage order, caching and background load, these timings should not be treated as portable latency ratios. Reported MLX peak inference allocations are 2.716 GB and 2.959 GB; neither value represents total system or training memory. The saved adapter is 6,657,883 bytes (approximately 6.35 MiB).

For Fresh V3, measured model-call time rises from 228.58 seconds in the full-record condition to 1,324.53 seconds for the cited condition, a 5.79-fold increase in this run. That additional cost accompanies lower overall accuracy. Requests, responses, model identifiers, configuration hashes and scoring artifacts are retained so that the results can be audited [6]. The LoRA audit verifies 212 expected arm/example records, adapter settings, source separation, parsing and the step-100 checkpoint fingerprint. Tensor inspection finds 56 finite F32 tensors in layers 32–35 with nonzero B matrices. These checks support archive consistency, but do not independently reproduce native execution on another machine or rule out pretraining exposure to the evaluated vulnerabilities.

VI. Discussion and Threats to Validity

The clearest result is not that adding more instructions or evidence always helps. Instead, each intervention changes a different part of the system. Evidence-first prompts improve KCV while harming other tasks; cited retrieval can identify the relevant source text and still misinterpret it; and a small supervised adapter improves matched KCV validation, largely by recovering true claims. These distinctions matter when deciding what to deploy. Locating a field is not the same as understanding it, producing a valid response format is not the same as choosing the correct label, and abstaining on an all-X task is not the same as calibrated abstention across varied questions.

Several limitations restrict our conclusions. The adapter validation set is relatively small, uses one seed and covers only one model family. The Fresh V3 claims come from templates and machine-derived labels rather than a diverse set of independently written analyst questions; full human label review is not complete. Group-based bootstrapping addresses some source dependence but cannot remove bias introduced by dataset construction. Different quantization and inference runtimes also prevent a direct causal comparison between the Ollama and MLX results.

Finally, the six-task test and adapter validation have both already been inspected, and their results have informed subsequent decisions. They can no longer serve as untouched tests for future tuning. The strongest next experiment would freeze the step-100 adapter and compare it with the matched base on a genuinely new, independently prepared collection of CVEs. That collection should include supported, contradicted and insufficient-evidence claims, with clear evidence boundaries and preserved raw responses. Repeated training seeds and evaluations on the remaining SECURE tasks are also needed before claiming a broader gain.

VII. Conclusion

This study examined cybersecurity claim verification through three local experiments involving prompting, retrieval and lightweight adaptation. Across the six SECURE tasks, explicit evidence-oriented prompting improved some classification results but reduced performance on risk-text overlap and CVSS scoring. On 160 additional CVE claims, the cited-retrieval candidate reached 68.125% accuracy, compared with 91.25% for the full-record condition. The frequent mismatch between literal citations and correct decisions shows why citation checking alone is not enough.

The fixed 100-step LoRA adapter increased matched KCV validation accuracy from 64.15% to 79.25%, mainly by improving recognition of true claims. This is a measured gain on observed validation data, not proof of transfer to unseen CVEs or superiority over the original SECURE authors. The practical contribution is a transparent comparison that records both improvements and failures, and keeps prompting, retrieval and adaptation effects clearly separated.

References

[1] D. Bhusal *et al.*, "SECURE: Benchmarking Large Language Models for Cybersecurity," in *Annual Computer Security Applications Conference (ACSAC)*, 2024, doi: 10.1109/ACSAC63791.2024.00019.

[2] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems*, vol. 33, pp. 9459–9474, 2020.

[3] E. J. Hu *et al.*, "LoRA: Low-Rank Adaptation of Large Language Models," in *International Conference on Learning Representations*, 2022, arXiv:2106.09685.

[4] K. Saurabh *et al.*, "HMS-IDS: Threat Intelligence Integration for Zero-Day Exploits and Advanced Persistent Threats in IIoT," *Arabian Journal for Science and Engineering*, vol. 50, pp. 1307–1327, 2025, doi: 10.1007/s13369-024-08935-5.

[5] FIRST, "Common Vulnerability Scoring System v3.1: Specification Document," sec. 2.1.4. [Online]. Available: https://www.first.org/cvss/v3-1/specification-document.

[6] T. S. Tomar, "SECURE-RAG implementation and archived experiment records," project software and accompanying submission artifacts, 2026. [Online]. Available: https://github.com/iTulsi/SECURE-RAG.